

Tentu. Untuk belajar Boot2Root, cara terbaik adalah membuat **lab lokal** (VirtualBox/VMware/Proxmox) yang sengaja rentan. Dengan begitu Anda bisa berlatih enumerasi, menemukan kelemahan, dan melakukan privilege escalation secara legal dan aman.

Desain Mesin Boot2Root Easy

Target Pembelajaran

Peserta belajar:

1. Service Enumeration
2. Web Enumeration
3. Credential Discovery
4. SSH Access
5. Privilege Escalation melalui SUID

Difficulty

Easy

Jalur Penyelesaian

Nmap

↓

Web Enumeration

↓

Backup File Leak

↓

Menemukan Credential

↓

SSH Login

↓

Menemukan Binary SUID Salah Konfigurasi

↓

Root

Struktur VM

OS:

- Ubuntu Server 22.04

Hostname:

easybox

User:

student

Password:

student123

Root password:

rootpassword

(Jangan tampilkan ke peserta.)

Service yang Dibuka

SSH

Port:

22

Install:

sudo apt install openssh-server

Apache

Port:

80

Install:

sudo apt install apache2

Initial Access

Web Server

Buat website sederhana:

```
<h1>Welcome To EasyBox</h1>
```

Simpan:

```
/var/www/html/index.html
```

Backup File Leak

Buat file:

`/var/www/html/backup.zip`

Isi ZIP:

`db.conf`

Isi `db.conf`:

`username=student`

`password=student123`

Peserta harus:

1. Enumerasi web
 2. Menemukan `backup.zip`
 3. Mengekstrak file
 4. Mendapat credential
-

User Flag

Login SSH:

`ssh student@target`

Buat flag:

`/home/student/user.txt`

Isi:

`FLAG{user_access_obtained}`

Permission:

`chmod 600 user.txt`

Privilege Escalation

Metode: SUID Misconfiguration

Gunakan binary yang memang umum dipelajari dalam lab.

Misalnya:

`cp /usr/bin/find /usr/local/bin/findroot`

Set owner:

`sudo chown root:root /usr/local/bin/findroot`

Set SUID:

`sudo chmod 4755 /usr/local/bin/findroot`

Peserta saat enumerasi menemukan:

```
find / -perm -4000 2>/dev/null
```

dan melihat:

```
/usr/local/bin/findroot
```

Petunjuk:

Nothing interesting here...

di:

```
/opt/note.txt
```

yang mengarahkan mereka untuk mengecek binary SUID.

Root Flag

Buat:

```
/root/root.txt
```

Isi:

```
FLAG{easybox_root_owned}
```

Permission:

```
chmod 600 root.txt
```

Cerita (Storyline)

Misalnya:

Administrator membuat backup konfigurasi dan lupa menghapusnya dari web server. Selain itu terdapat binary SUID yang tidak seharusnya diberikan hak istimewa.

Ini membuat jalur eksploitasi terasa realistis.

Checklist Pembuat Challenge

Enumerasi

Peserta harus menemukan:

- Port 22
- Port 80

Web

Peserta harus menemukan:

- backup.zip

Credential

Peserta harus memperoleh:

student : student123

SSH

Peserta harus membaca:

user.txt

PrivEsc

Peserta harus:

- menemukan binary SUID yang tidak semestinya
- memahami mengapa pemberian hak tersebut berbahaya
- memperoleh akses root di lingkungan lab

Root

Peserta membaca:

root.txt

Setelah Easy

Urutan peningkatan kesulitan yang bagus:

Easy

- Backup leak
- Credential reuse
- SUID

Medium

- LFI
- Database credential reuse
- sudo misconfiguration
- cron abuse

Hard

- CVE exploitation
- Docker breakout (lab)
- Capabilities abuse
- Multi-user privilege escalation

- Active Directory pivoting (Windows)

Dengan pendekatan ini Anda belajar seluruh alur Boot2Root secara bertahap tanpa perlu menggunakan kerentanan berbahaya pada sistem nyata.